HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN

BÁO CÁO BÀI THỰC HÀNH
HỌC PHẦN: THỰC TẬP CƠ SỞ
MÃ HỌC PHẦN: INT13147

BÀI THỰC HÀNH 2.2

TÌM HIỂU VÀ CÀI ĐẶT, CẤU HÌNH NIDS

Sinh viên thực hiện:

B22DCAT278 Đỗ Hồng Thái

Giảng viên hướng dẫn: Vũ Minh Mạnh

HỌC KỲ 2 NĂM HỌC 2024-2025

Mục lục

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH.....3
1.1 Mục đích.....3
1.2 Tìm hiểu lý thuyết.....3
1.2.1 Tìm hiểu khái quát về các hệ thống phát hiện tấn công, xâm nhập, phân loại các hệ thống phát hiện xâm nhập, các kỹ thuật phát hiện xâm nhập.....3
A. Giới thiệu về hệ thống phát hiện tấn công, xâm nhập.....3
B. phân loại các hệ thống phát hiện xâm nhập.....4
C. Các kỹ thuật phát hiện xâm nhập.....6
1.2.2: Tìm hiểu về kiến trúc và tính năng của một số hệ thống phát hiện tấn công, xâm nhập: Snort, OSSEC.....8
1.2.2.1. Snort.....8
1.2.2.2. Ossec.....10
CHƯƠNG 2. NỘI DUNG THỰC HÀNH.....11
2.1 Chuẩn bị môi trường.....11
2.2 Các bước thực hiện.....12
2.3 Kết luận.....20
TÀI LIỆU THAM KHẢO.....20

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH

1.1 Mục đích

Mục đích của bài thực hành "2.2: Tìm hiểu và cài đặt, cấu hình NIDS" là:

- Tìm hiểu và luyện tập việc cài đặt và vận hành các hệ thống phát hiện xâm nhập cho host (HIDS) và cho mạng (NIDS).

- Luyện tập việc tạo và chỉnh sửa các luật phát hiện tấn công, xâm nhập cho các hệ thống phát hiện xâm nhập thông dụng.

1.2 Tìm hiểu lý thuyết

1.2.1 Tìm hiểu khái quát về các hệ thống phát hiện tấn công, xâm nhập, phân loại các hệ thống phát hiện xâm nhập, các kỹ thuật phát hiện xâm nhập.

A. Giới thiệu về hệ thống phát hiện tấn công, xâm nhập

Hệ thống phát hiện xâm nhập (Intrusion Detection System - IDS) là một công cụ quan trọng trong việc bảo mật mạng và hệ thống máy tính. IDS giúp giám sát và phân tích các hoạt động trong hệ thống nhằm phát hiện các hành vi đáng ngờ hoặc các cuộc tấn công có thể xảy ra. Mục tiêu chính của IDS là nhận diện các xâm nhập trái phép hoặc các hành vi không mong muốn, giúp ngăn ngừa tổn thất và bảo vệ tài nguyên quan trọng.

Chức năng của IDS:

Giám sát và phân tích lưu lượng mạng: IDS liên tục giám sát và phân tích lưu lượng mạng hoặc các hoạt động hệ thống để phát hiện các dấu hiệu của tấn công.

Phát hiện các mối đe dọa: IDS có thể phát hiện các cuộc tấn công như DoS (Denial of Service), tấn công SQL Injection, tấn công brute force, và nhiều mối đe dọa khác.

Cảnh báo và báo cáo: Khi phát hiện có dấu hiệu của một cuộc tấn công hoặc hành vi đáng ngờ, IDS sẽ gửi cảnh báo cho quản trị viên để xử lý kịp thời.

Thu thập và lưu trữ dữ liệu: IDS có thể ghi lại các sự kiện và lưu trữ thông tin về các cuộc tấn công để phục vụ cho việc phân tích sau này và cung cấp bằng chứng trong trường hợp cần thiết.

Ưu điểm và nhược điểm của IDS

Ưu điểm:

Phát hiện sớm các cuộc tấn công: IDS giúp phát hiện các mối đe dọa và tấn công trước khi chúng có thể gây hại nghiêm trọng cho hệ thống.

Bảo mật mạng và hệ thống: Tăng cường an ninh mạng, giúp bảo vệ các tài nguyên quan trọng khỏi sự xâm nhập trái phép.

Nhược điểm:

Cảnh báo giả: Đặc biệt đối với IDS theo hành vi, đôi khi có thể đưa ra cảnh báo sai, gây nhầm lẫn và giảm hiệu quả hoạt động.

Tốn kém tài nguyên: Các hệ thống IDS yêu cầu tài nguyên tính toán và băng thông lớn, đặc biệt trong môi trường có lưu lượng mạng cao.

Tóm lại, hệ thống phát hiện xâm nhập là một phần quan trọng trong chiến lược bảo mật mạng và hệ thống. Chúng giúp phát hiện và cảnh báo các cuộc tấn công ngay từ giai đoạn đầu, giúp ngăn chặn và giảm thiểu thiệt hại cho các hệ thống quan trọng.

B. phân loại các hệ thống phát hiện xâm nhập

Các hệ thống phát hiện xâm nhập (Intrusion Detection Systems - IDS) có thể được phân loại theo nhiều tiêu chí khác nhau. Dưới đây là một số cách phân loại IDS phổ biến:

Dựa trên phương thức phát hiện

IDS có thể được phân loại dựa trên cách thức phát hiện các cuộc tấn công hoặc xâm nhập:

IDS theo dấu hiệu (Signature-based IDS):

Phát hiện các cuộc tấn công bằng cách so sánh hành vi của hệ thống với một cơ sở dữ liệu chứa các dấu hiệu (signature) của các cuộc tấn công đã biết.

Ưu điểm: Độ chính xác cao khi phát hiện các tấn công đã biết.

Nhược điểm: Không thể phát hiện các cuộc tấn công mới hoặc chưa có dấu hiệu trong cơ sở dữ liệu.

IDS theo hành vi (Anomaly-based IDS):

Phát hiện xâm nhập dựa trên việc phân tích hành vi của hệ thống và so sánh với các hành vi "bình thường". Nếu có sự khác biệt đáng kể, hệ thống sẽ đưa ra cảnh báo.

Ưu điểm: Có thể phát hiện các cuộc tấn công mới mà chưa có dấu hiệu.

Nhược điểm: Dễ bị cảnh báo giả (false positives), khi hành vi bất thường không phải lúc nào cũng là tấn công.

Dựa trên vị trí triển khai

Hệ thống IDS có thể được triển khai ở nhiều vị trí khác nhau trong hạ tầng mạng và hệ thống:

IDS mạng (Network-based IDS - NIDS): Được triển khai trên mạng, giám sát lưu lượng dữ liệu đi qua mạng để phát hiện các cuộc tấn công như tấn công DoS (Denial of Service), sniffing, và các tấn công mạng khác.

IDS máy chủ (Host-based IDS - HIDS): Được cài đặt trực tiếp trên các máy tính hoặc máy chủ, giám sát các hoạt động trên hệ thống (như file system, log files, các thay đổi hệ thống, etc.).

Dựa trên cách thức phản hồi

IDS cũng có thể được phân loại dựa trên cách thức phản hồi khi phát hiện xâm nhập:

IDS bị động (Passive IDS):Chỉ phát hiện và cảnh báo về các hành vi đáng ngờ mà không có khả năng ngăn chặn chúng. Nó giúp quản trị viên nhận diện và xử lý sự cố sau khi đã xảy ra.

IDS chủ động (Active IDS): Không chỉ phát hiện mà còn có khả năng phản ứng trực tiếp để ngăn chặn hoặc giảm thiểu các cuộc tấn công. Các phản ứng có thể bao gồm việc chặn IP tấn công, ngắt kết nối, hoặc thay đổi cấu hình hệ thống.

Dựa trên kiến trúc hệ thống

Các IDS có thể được phân loại dựa trên cách tổ chức và kết nối các thành phần trong hệ thống:

Hệ thống phân tán (Distributed IDS):Gồm nhiều máy chủ hoặc thiết bị phân tán, mỗi IDS trên các máy chủ con sẽ giám sát các khu vực khác nhau của mạng hoặc hệ thống. Sau đó, các thông tin thu thập được sẽ được tổng hợp và phân tích tại một điểm trung tâm.

Hệ thống tập trung (Centralized IDS):Tất cả dữ liệu và phân tích được thực hiện tại một điểm duy nhất. Dữ liệu từ các hệ thống hoặc máy chủ được gửi về một trung tâm giám sát duy nhất để phân tích.

Dựa trên mục đích sử dụng

Hệ thống IDS có thể được phân loại theo mục đích và môi trường sử dụng:

IDS cho mạng doanh nghiệp:Được triển khai để bảo vệ hạ tầng mạng của các tổ chức và doanh nghiệp lớn khỏi các cuộc tấn công từ bên ngoài và bên trong. Đây thường là các hệ thống có tính năng nâng cao và yêu cầu tính ổn định cao.

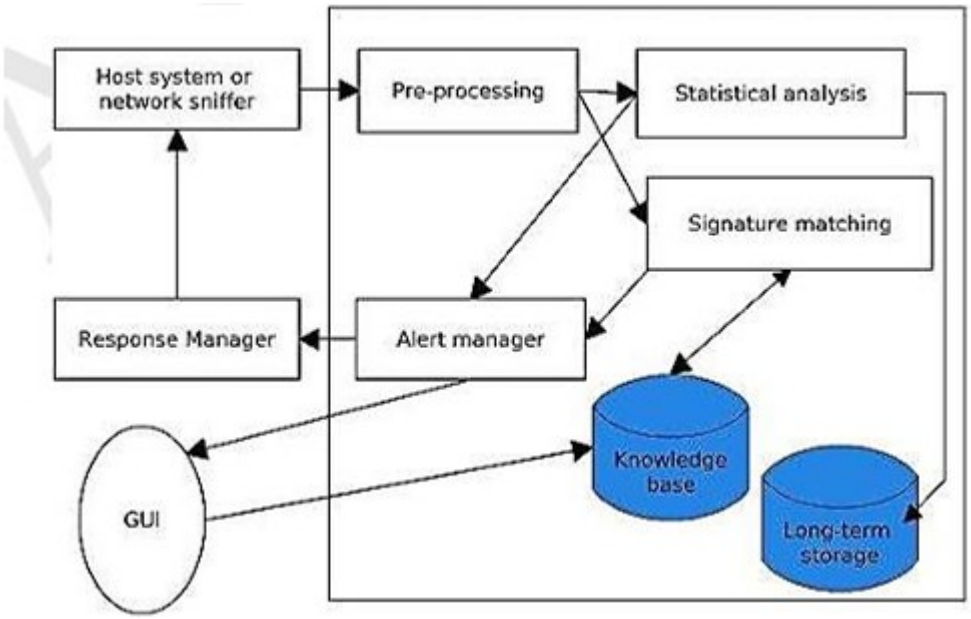
IDS cho môi trường điện toán đám mây:Các hệ thống IDS được tối ưu hóa để hoạt động trong môi trường điện toán đám mây, bảo vệ các ứng dụng và dữ liệu được lưu trữ trên các dịch vụ đám mây.

IDS cho thiết bị di động:Các hệ thống IDS được thiết kế đặc biệt để bảo vệ các thiết bị di động và hệ thống IoT khỏi các mối đe dọa, đặc biệt là khi các thiết bị này kết nối với các mạng không dây.

C. Các kỹ thuật phát hiện xâm nhập

Phát hiện xâm nhập dựa trên chữ ký:

Phát hiện xâm nhập dựa trên chữ ký trước hết cần xây dựng cơ sở dữ liệu các chữ ký, hoặc các dấu hiệu của các loại tấn công, xâm nhập đã biết. Hầu hết các chữ ký, dấu hiệu được nhận dạng và mã hóa thủ công và dạng biểu diễn thường gặp là các luật phát hiện (Detection rule). Bước tiếp theo là sử dụng cơ sở dữ liệu các chữ ký để giám sát các hành vi của hệ thống, hoặc mạng, và cảnh báo nếu phát hiện chữ ký của tấn công, xâm nhập. Hình dưới đây biểu diễn lưu đồ giám sát phát hiện tấn công, xâm nhập dựa trên chữ ký điển hình, trong đó Knowledge base là cơ sở dữ liệu lưu các chữ ký tấn công, xâm nhập.

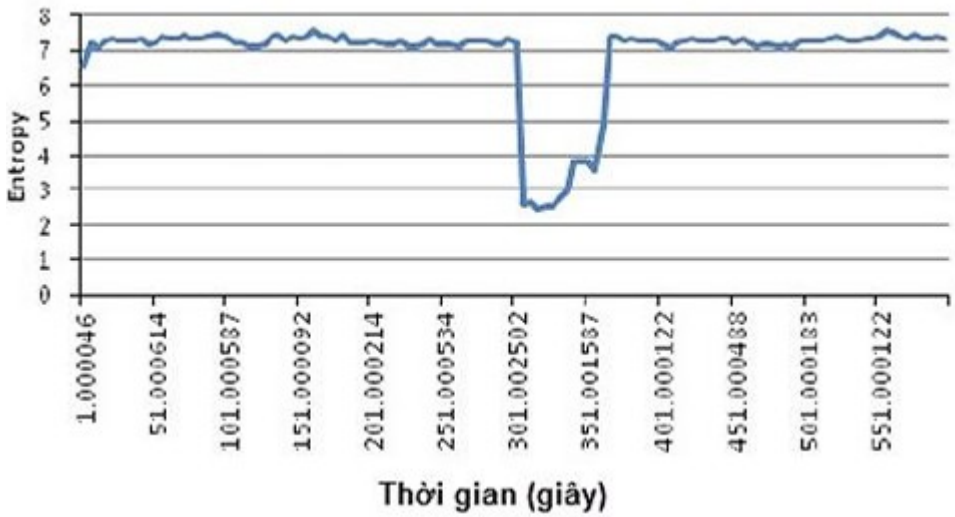


Ưu điểm lớn nhất của phát hiện xâm nhập dựa trên chữ ký là có khả năng phát hiện các tấn công, xâm nhập đã biết một cách hiệu quả. Ngoài ra, phương pháp

này cho tốc độ xử lý cao, đồng thời yêu cầu tài nguyên tính toán tương đối thấp. Nhờ vậy, các hệ thống phát hiện xâm nhập dựa trên chữ ký được ứng dụng rộng rãi trong thực tế. Tuy nhiên, nhược điểm chính của phương pháp này là không có khả năng phát hiện các tấn công, xâm nhập mới, do chữ ký của chúng chưa tồn tại trong cơ sở dữ liệu các chữ ký. Hơn nữa, phương pháp này cũng đòi hỏi nhiều công sức xây dựng và cập nhật cơ sở dữ liệu chữ ký, dấu hiệu của các tấn công, xâm nhập.

Phát hiện xâm nhập dựa trên bất thường

Phát hiện xâm nhập dựa trên bất thường dựa trên giả thiết: các hành vi tấn công, xâm nhập thường có quan hệ chặt chẽ với các hành vi bất thường. Quá trình xây dựng và triển khai một hệ thống phát hiện xâm nhập dựa trên bất thường thường gồm 2 giai đoạn: (1) huấn luyện và (2) phát hiện. Trong giai đoạn huấn luyện, hồ sơ (profile) của đối tượng trong chế độ làm việc bình thường được xây dựng. Để thực hiện giai đoạn huấn luyện, cần giám sát đối tượng trong một khoảng thời gian đủ dài để thu thập được đầy đủ dữ liệu mô tả các hành vi của đối tượng trong điều kiện bình thường làm dữ liệu huấn luyện. Tiếp theo, thực hiện huấn luyện dữ liệu để xây dựng mô hình phát hiện, hay hồ sơ của đối tượng. Trong giai đoạn phát hiện, thực hiện giám sát hành vi hiện tại của hệ thống và cảnh báo nếu có khác biệt rõ nét giữa hành vi hiện tại và các hành vi lưu trong hồ sơ của đối tượng.



Hình trên biểu diễn giá trị entropy của IP nguồn của các gói tin theo cửa sổ trượt từ lưu lượng bình thường và entropy của IP nguồn của các gói tin từ lưu lượng tấn công DDoS. Có thể thấy sự khác biệt rõ nét giữa giá trị entropy của lưu lượng bình thường và lưu lượng tấn công và như vậy nếu một ngưỡng entropy được chọn phù hợp ta hoàn toàn có thể phát hiện sự xuất hiện của cuộc tấn công DDoS dựa trên sự thay đổi đột biến của giá trị entropy. Ưu điểm của phát hiện xâm nhập dựa trên bất thường là có tiềm năng phát hiện các loại tấn công, xâm nhập mới mà không yêu cầu biết trước thông tin về chúng. Tuy nhiên, phương pháp này thường có tỷ lệ cảnh báo sai tương đối cao so với phương pháp phát hiện dựa trên chữ ký. Điều này làm giảm khả năng ứng dụng thực tế của phát hiện xâm nhập dựa trên bất

thường. Ngoài ra, phương pháp này cũng tiêu tốn nhiều tài nguyên hệ thống cho việc xây dựng hồ sơ đối tượng và phân tích hành vi hiện tại.

1.2.2: Tìm hiểu về kiến trúc và tính năng của một số hệ thống phát hiện tấn công, xâm nhập: Snort, OSSEC.

1.2.2.1. Snort

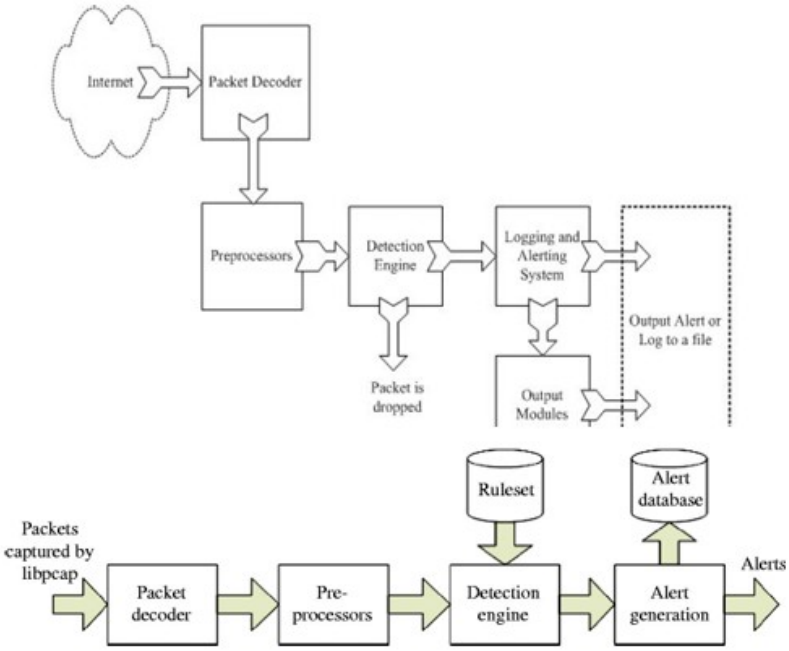
a. Giới thiệu

Snort là một công cụ IDS/IPS, thực hiện giám sát các gói tin ra vào hệ thống.

− Snort là một mã nguồn mở miễn phí với nhiều tính năng trong việc bảo vệ hệ thống bên trong, phát hiện sự tấn công từ bên ngoài vào hệ thống.

− Snort được viết bởi Martin Roesch vào năm 1998. Hiện tại, Snort được phát triển bởi Sourcefire, nơi mà Roesch đang là người sáng lập và CTO, và được sở hữu bởi Cisco từ năm 2013.

b. Kiến trúc của Snort



Trong mô hình kiến trúc trên, hệ thống Snort được chia thành 4 phần:

− Module Decoder: Xử lý giải mã các gói tin

− Module Preprocessors: Tiền xử lý

− Module Detection Engine: Phát hiện

− Module Logging and Alerting System: Lưu log và cảnh báo

c. Các luật của Snort

Cấu trúc của một rule được chia thành 02 phần: |Rule header|Rule Option|

− Phần Header: Chứa thông tin về hành động mà luật đó sẽ thực hiện khi phát hiện ra có xâm nhập nằm trong gói tin và nó cũng chứa tiêu chuẩn để áp dụng luật với gói tin đó.

− Phần Option: Chứa thông điệp cảnh báo và các thông tin về các phần của gói tin dùng để tạo nên cảnh báo. Phần Option này chưa các tiêu chuẩn phụ thêm để đối sánh với gói tin

Cấu trúc phần Header:|Action|Protocol|Address|port|Direction|Address| Port|

− Action: Thể hiện hành động sẽ được thực hiện khi một gói tin kích hoạt quy tắc. Trong đó:

+ alert: Tạo một cảnh báo và ghi lại gói tin.

+ log: Chỉ ghi lại gói tin mà không tạo cảnh báo.

+ pass: Bỏ qua gói tin, không thực hiện hành động nào.

+ activate: Tạo ra cảnh báo và kích hoạt thêm các luật khác để kiểm tra thêm điều kiện của gói tin

+ dynamic: Đây là luật được gọi bởi các luật khác có Action khai báo là Activate

− Protocol: Xác định loại giao thức của gói tin, ví dụ: TCP, UDP, ICMP, hoặc any (tất cả).

− Source IP Address: Địa chỉ IP nguồn của gói tin.

− Source Port: Cổng nguồn của gói tin. Có thể là một số cụ thể hoặc từ khoảng cụ thể.

− Direction Operator: Thể hiện hướng của gói tin. Có thể là -> (nguồn tới đích) hoặc <- (đích tới nguồn).

− Destination IP Address: Địa chỉ IP đích của gói tin.

− Destination Port: Cổng đích của gói tin. Cũng có thể là một số cụ thể hoặc từ khoảng cụ thể.

Cấu trúc phần Option: Phần Option nằm ngay sau phần Header và được bao bọc trong dấu ngoặc đơn. Nếu có nhiều Option thì sẽ phân biệt bởi dấu chấm phẩy ";". Một Option gồm có 2 phần: một là từ khóa và một là tham số. 02 phần này sẽ phân cách nhau bằng dấu hai chấm ":" Các option có thể là: msg (tin nhắn cảnh báo), content (nội dung gói tin), sid (số nhận dạng duy nhất), rev (số phiên bản quy tắc), content: Chứa một chuỗi hoặc byte pattern để so khớp với dữ liệu gói tin …

1.2.2.2. Ossec

a. Ossec là gì?

OSSEC là phần mềm mã nguồn mở giúp phát hiện xâm nhập dựa trên host (HIDS) Nó đa nền tảng, có thể mở rộng và có nhiều cơ chế bảo mật khác nhau.

b. Các tính năng của Ossec

− Log based Intrusion Detection (LIDs) and Log Monitoring:

+ Chủ động theo dõi và phân tích dữ liệu real-time từ nhiều nguồn sinh log.

+ Ngoài ra, Ossec sẽ thu thập, phân tích và kiểm tra mối tương quan các log và cho ta biết những điều đáng ngờ đang xảy ra trong hệ thống (bị tấn công, lỗi, sử dụng sai,..), các phần mềm được cài đặt thêm, các rule firewall bị đổi.

− Compliance Auditing:

+ Kiểm soát các ứng dụng và hệ thống nhằm tuân thủ các yêu cầu, tiêu chuẩn về bảo mật như PCI-DSS và CIS.

− Rootkit and Malware Detection:

+ Tin tặc thường muốn che dấu hành động và quay lại hệ thống đã xâm nhập được

+ Ossec phân tích ở cấp độ file và tiến trình nhằm phát hiện các ứng dụng độc hại, các rootkit hay các file hệ thống bị sửa đổi theo cách phổ biến với rootkit

− File Integrity Monitoring (FIM):

+ Phát hiện các thay đổi đối với hệ thống.

− Active Response:

+ Các hành vi ứng phó lại các cuộc tấn công vào hệ thống trong thời gian thực.

+ Giúp ngăn sự cố lan rộng trước khi admin có thể hành động

− System Inventory:

+ Thu thập các thông tin hệ thống như phần mềm được cài đặt, harware,…

c. Điểm nổi trội của Ossec

− Đa nền tảng (Linux, Mac OS, Window, Solaris)

− Real-time Alert (Cảnh báo thời gian thực)

+ Kết hợp với smtp, sms, syslog sẽ cho phép người dùng nhận cảnh báo trên các thiết bị có hỗ trợ email

+ Ngoài ra tính năng Active-respone có thể giúp block 1 cuộc tấn công ngay lập tức.

− Có thể tích hợp với các hệ thống hiện đại (SIM/SEM)

− Mô hình Server – Agent/Agentless, cho phép Server dễ dàng quản lý tập trung các chính sách trên nhiều OS.

− Giám sát trên agent, agentless (Client không cài đặt được gói agent) như router, firewall

d. Kiến trúc và mô hình hoạt động của Ossec

Ossec hoạt động theo mô hình Server-Agent/Agentles

Manager (Server) :Lưu trữ cơ sở dữ liệu của việc kiểm tra tính toàn vẹn file; Kiểm tra các log, event. Quản lý, lưu tất cả các rule, decoder (bộ giải mã), cấu hình chính. Điều này giúp dễ dàng quản lý, dù cho có lượng lớn Agent Server không chạy trên Windows OS.

Agent: Bản chất thì là 1 phần mềm được cài đặt trên máy client giúp thu thập các thông tin và gửi cho Server để phân tích, thống kê. Chiếm lượng memory và CPU nhỏ, không đáng kể. Một số thông tin được thu thập theo thời gian thực. Một số thông tin thì lại được thu thập định kỳ. Nhưng khi nói Agent thì là để chỉ máy Client được cài gói Ossec-agent.

CHƯƠNG 2. NỘI DUNG THỰC HÀNH

2.1 Chuẩn bị môi trường

- 01 máy tính (máy thật hoặc máy ảo) chạy Linux với RAM tối thiểu 2GB, 10GB đĩa cứng có kết nối mạng (LAN hoặc Internet).

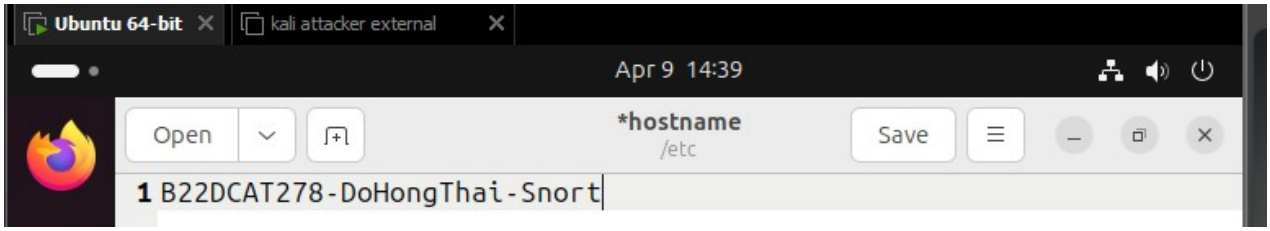
- 01 máy tính (máy thật hoặc máy ảo) chạy Kali Linux (bản 2021 trở lên)

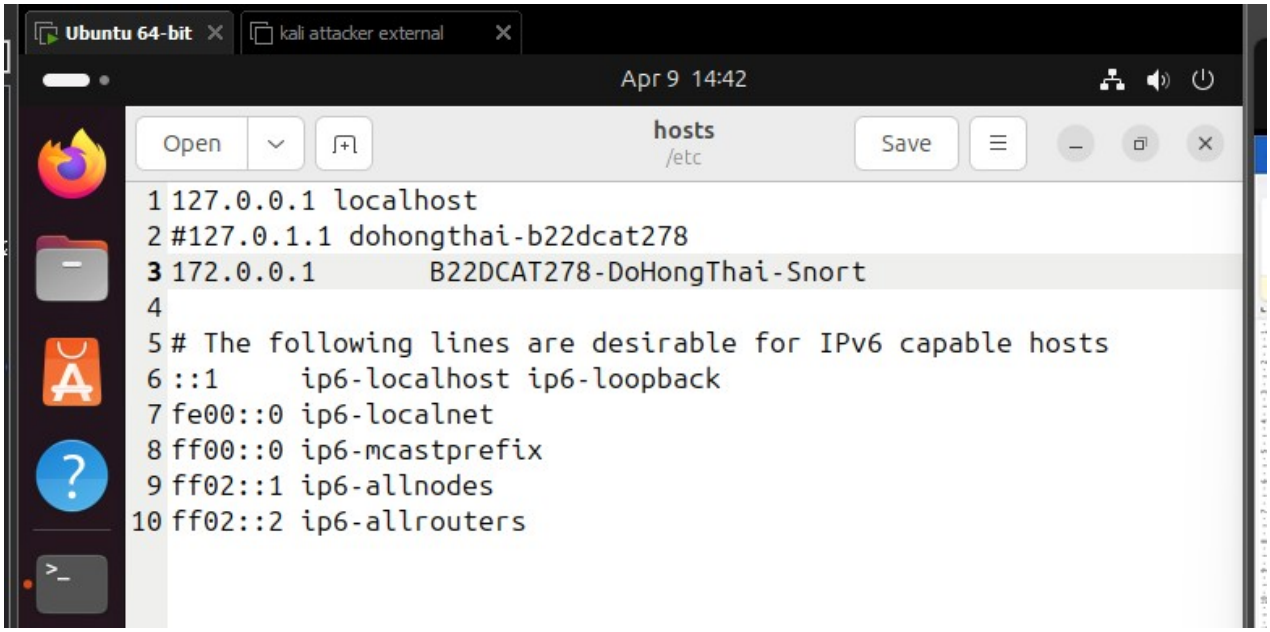
- Bộ phần mềm Snort tải tại https://www.snort.org/downloads

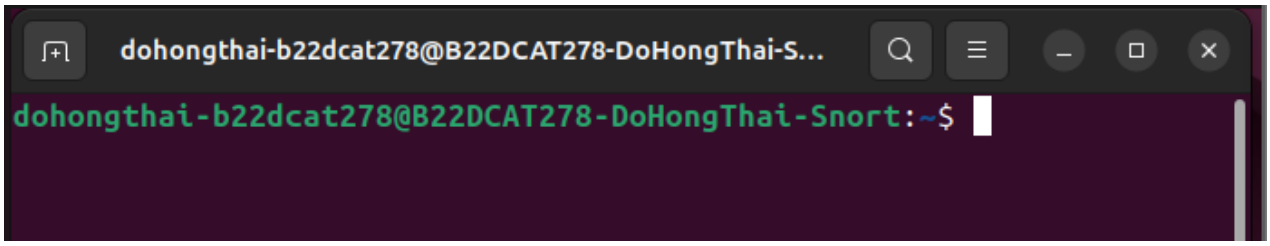
2.2 Các bước thực hiện

- Bước 1: Chuẩn bị các máy tính như mô tả trong mục 2.2. Máy Kali Linux được đổi tên thành <Mã SV - Tên SV>-Kali và máy cài Snort thành<Mã Sv-Tên SV> - Snort. Các máy có địa chỉ IP và kết nối mạng LAN.

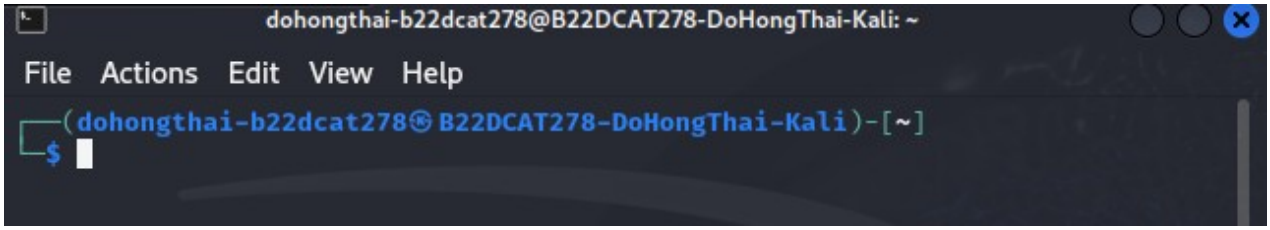
+ Với máy cài snort:







+ Tương tự với máy kali linux ta có như sau:



- Bước 2: Tải, cài đặt Snort và chạy thử Snort. Kiểm tra log của Snort để đảm bảo Snort hoạt động bình thường.

+ Tải snort:

sudo apt update

sudo apt install snort

```
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort:~$ sudo apt insta
ll snort
Waiting for cache lock: Could not get lock /var/lib/dpkg/lock-front
Waiting for cache lock: Could not get lock /var/lib/dpkg/lock-front
end. It is held by process 4790 (unattended-upgr)
Waiting for cache lock: Could not get lock /var/lib/dpkg/lock-front
Waiting for cache lock: Could not get lock /var/lib/dpkg/lock-front
end. It is held by process 4790 (unattended-upgr)
Reading package lists... 0%
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following packages were automatically installed and are no long
er required:
  libllvm17t64 python3-netifaces
Use 'sudo apt autoremove' to remove them.
The following additional packages will be installed:
  libdaq2t64 libdumbnet1 libluajit-5.1-2 libluajit-5.1-common
  libnetfilter-queue1 libpcre3 oinkmaster snort-common
  snort-common-libraries snort-rules-default
```

+ Kiểm tra phiên bản của snort:

```
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort:~$ snort --versio
n

   ,,_     -*> Snort! <*-
  o"  )~   Version 2.9.20 GRE (Build 82)
   ''''    By Martin Roesch & The Snort Team: http://www.snort.org/
contact#team
           Copyright (C) 2014-2022 Cisco and/or its affiliates. All
 rights reserved.
           Copyright (C) 1998-2013 Sourcefire, Inc., et al.
           Using libpcap version 1.10.4 (with TPACKET_V3)
           Using PCRE version: 8.39 2016-06-14
           Using ZLIB version: 1.3
```

+ Kiểm tra trạng thái của snort

```
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort:~$ systemctl stat
us snort
● snort.service - LSB: Lightweight network intrusion detection sys>
     Loaded: loaded (/etc/init.d/snort; generated)
     Active: active (running) since Wed 2025-04-09 15:18:18 +07; 2>
       Docs: man:systemd-sysv-generator(8)
      Tasks: 2 (limit: 4551)
     Memory: 79.9M (peak: 95.7M)
        CPU: 898ms
     CGroup: /system.slice/snort.service
             └─5746 /usr/sbin/snort -m 027 -D -d -l /var/log/snort>

Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]:          >
Apr 09 15:18:18 B22DCAT278-DoHongThai-Snort snort[5746]: Commencin>
lines 1-20/20 (END)
```

restore.

+ Khởi chạy snort và giám sát trên card mạng ens33

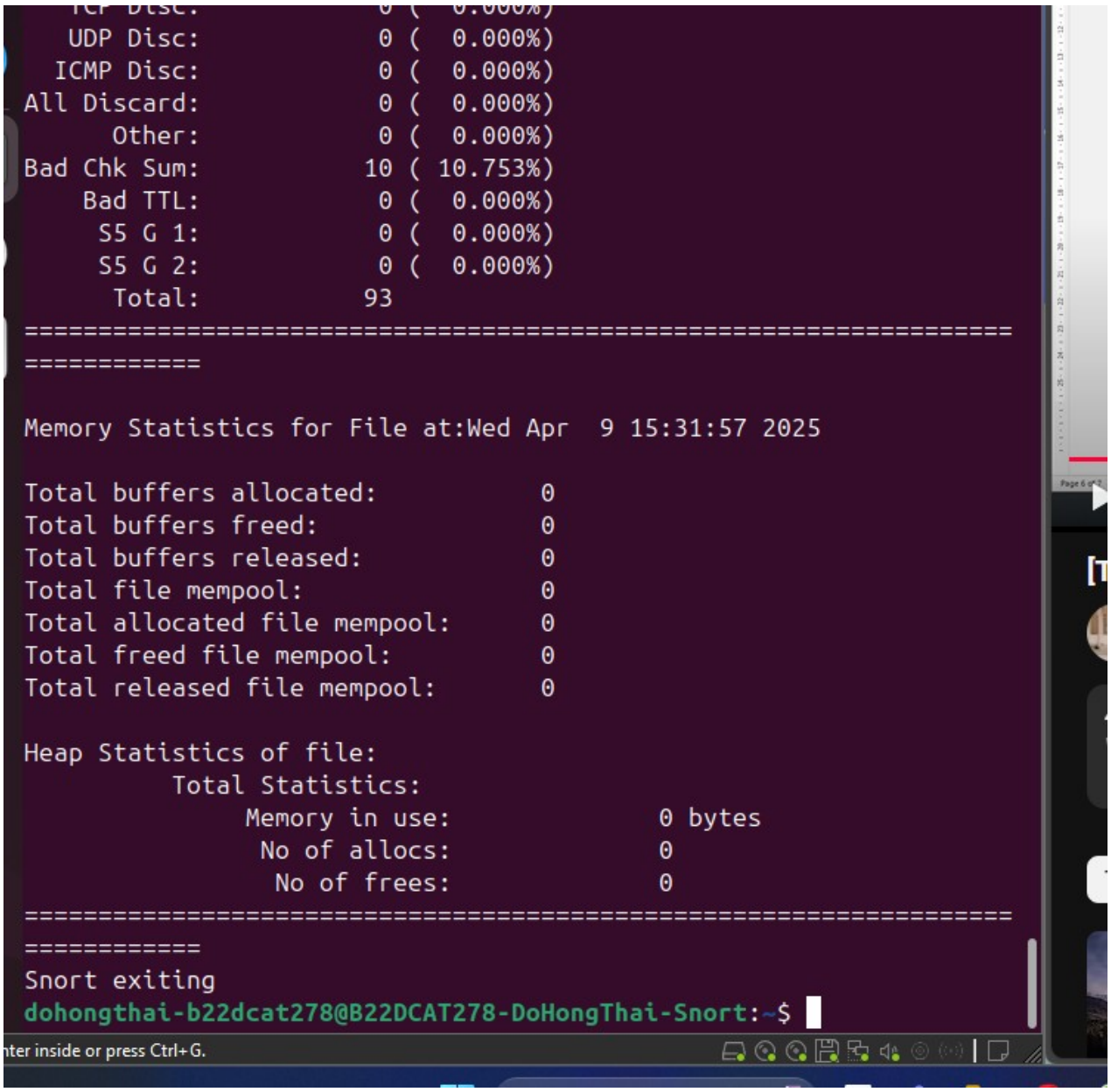
```
dohongthai-b22dcat278@B22DCAT278-DoHongThai-S...
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort:~$ sudo snort -v
-i ens33
[sudo] password for dohongthai-b22dcat278:
Running in packet dump mode

        --== Initializing Snort ==--
Initializing Output Plugins!
pcap DAQ configured to passive.
Acquiring network traffic from "ens33".
Decoding Ethernet

        --== Initialization Complete ==--

   ,,_     -*> Snort! <*-
  o"  )~   Version 2.9.20 GRE (Build 82)
   ''''    By Martin Roesch & The Snort Team: http://www.snort.org/
contact#team
           Copyright (C) 2014-2022 Cisco and/or its affiliates. All
 rights reserved.
           Copyright (C) 1998-2013 Sourcefire, Inc., et al.
           Using libpcap version 1.10.4 (with TPACKET_V3)
           Using PCRE version: 8.39 2016-06-14
           Using ZLIB version: 1.3
```

```
============
Memory usage summary:
  Total non-mmapped bytes (arena):       790528
  Bytes in mapped regions (hblkhd):      22941696
  Total allocated space (uordblks):      686560
  Total free space (fordblks):           103968
  Topmost releasable block (keepcost):   102224
=================================================================
============
Packet I/O Totals:
   Received:           96
   Analyzed:           93 ( 96.875%)
    Dropped:            0 (  0.000%)
   Filtered:            0 (  0.000%)
Outstanding:            3 (  3.125%)
   Injected:            0
=================================================================
============
Breakdown by protocol (includes rebuilt packets):
        Eth:           93 (100.000%)
       VLAN:            0 (  0.000%)
        IP4:           28 ( 30.108%)
       Frag:            0 (  0.000%)
       ICMP:            0 (  0.000%)
        UDP:           18 ( 19.355%)
        TCP:           10 ( 10.753%)
        IP6:           14 ( 15.054%)
```



- Bước 3: Tạo các luật Snort để phát hiện 3 dạng rà quét, tấn công hệ thống: + Phát hiện các gói tin ping từ bất kỳ một máy nào gửi đến máy chạy Snort. Hiển thị thông điệp khi phát hiện: "-Snort phát hiện có các gói Ping gửi đến."

+ Phát hiện các gói tin rà quét từ bất kỳ một máy nào gửi đến máy chạy Snort trên cổng 80. Hiển thị thông điệp khi phát hiện: "-Snort phát hiện có các gói tin rà quét trên cổng 80."

+ Phát hiện tấn công TCP SYN Flood từ bất kỳ một máy nào gửi đến máy chạy Snort. Hiển thị thông điệp khi phát hiện: "-Snort phát hiện đang bị tấn công TCP SYN Flood."

```
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
# ----------------
# LOCAL RULES
# ----------------
# This file intentionally does not come with signatures.  Put your local
# additions here.
# Rule 1: ping detect
alert icmp any any -> $HOME_NET any (msg:"B22DCAT278-DoHongThai-phat hien co cac goi ping den"; sid:1000001; rev:1;)

#rule 2: tmp scan port 80 detect
alert tcp any any -> $HOME_NET 80 (msg:"B22DCAT278-DoHongThai-phat hien co cac goi tin ra quet tren cong 80"; sid:1000002; rev:1;)

#rule 3: tcp syn flood detect
alert tcp any any -> $HOME_NET any (msg:"B22DCAT278-DoHongThai-phat hien dang bi tan cong tcp syn flood"; sid:1000003; rev:1;)
```

```
onfiguration file and re-enable
st line) those
ules files that are available in your system (in the /etc/snort/rules
irectory)

ite specific rules
lude $RULE_PATH/local.rules

he include files commented below have been disabled
ecause they are not available in the stock Debian
ules. If you install the Sourcefire VRT please make
ure you re-enable them again:

clude $RULE_PATH/app-detect.rules
lude $RULE_PATH/attack-responses.rules
lude $RULE_PATH/backdoor.rules
lude $RULE_PATH/bad-traffic.rules
clude $RULE_PATH/blacklist.rules
```

- Bước 4: thực thi tấn công và phát hiện sử dụng Snort

+ Từ máy Kali, sử dụng lệnh ping để ping máy Snort. Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort.

Ping từ máy Kali tới máy cài snort

```
┌──(dohongthai-b22dcat278㉿B22DCAT278-DoHongThai-Kali)-[~]
└─$ ping 192.168.100.147
PING 192.168.100.147 (192.168.100.147) 56(84) bytes of data.
64 bytes from 192.168.100.147: icmp_seq=1 ttl=64 time=3.82 ms
64 bytes from 192.168.100.147: icmp_seq=2 ttl=64 time=1.09 ms
64 bytes from 192.168.100.147: icmp_seq=3 ttl=64 time=0.638 ms
64 bytes from 192.168.100.147: icmp_seq=4 ttl=64 time=1.47 ms
64 bytes from 192.168.100.147: icmp_seq=5 ttl=64 time=1.04 ms
64 bytes from 192.168.100.147: icmp_seq=6 ttl=64 time=1.03 ms
64 bytes from 192.168.100.147: icmp_seq=7 ttl=64 time=0.899 ms
64 bytes from 192.168.100.147: icmp_seq=8 ttl=64 time=0.557 ms
64 bytes from 192.168.100.147: icmp_seq=9 ttl=64 time=0.684 ms
64 bytes from 192.168.100.147: icmp_seq=10 ttl=64 time=1.05 ms
^C
--- 192.168.100.147 ping statistics ---
10 packets transmitted, 10 received, 0% packet loss, time 9056ms
rtt min/avg/max/mdev = 0.557/1.226/3.817/0.899 ms

┌──(dohongthai-b22dcat278㉿B22DCAT278-DoHongThai-Kali)-[~]
```

Log của snort:

```
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort: ~
04/09-17:48:14.286700  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {IPV6-ICMP} fe80::123b:2cef:36f4:5349 -> ff02
::16
04/09-17:48:14.292984  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {IPV6-ICMP} fe80::123b:2cef:36f4:5349 -> ff02
::16
04/09-17:48:14.304779  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {IPV6-ICMP} fe80::123b:2cef:36f4:5349 -> ff02
::16
04/09-17:48:14.325295  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {IPV6-ICMP} fe80::123b:2cef:36f4:5349 -> ff02
::16
04/09-17:54:10.732670  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {IPV6-ICMP} fe80::20c:29ff:fec0:5f95 -> ff02:
:2
04/09-18:03:37.413662  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {ICMP} 192.168.100.148 -> 192.168.100.147
04/09-18:03:38.415183  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {ICMP} 192.168.100.148 -> 192.168.100.147
04/09-18:03:39.422382  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {ICMP} 192.168.100.148 -> 192.168.100.147
04/09-18:03:40.446365  [**] [1:1000001:1] B22DCAT278-DoHongThai-phat hien co ca
c goi ping den [**] [Priority: 0] {ICMP} 192.168.100.148 -> 192.168.100.147
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort:~$
```

+ Từ máy Kali, sử dụng công cụ nmap để rà quét máy Snort (dùng lệnh: nmap -sV -p80 A <địa chỉ IP máy Snort>). Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort.

Thực hiện nmap từ máy kali:

```
┌──(dohongthai-b22dcat278㉿B22DCAT278-DoHongThai-Kali)-[~]
└─$ nmap -sS -p80  192.168.100.147
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-09 07:17 EDT
Nmap scan report for 192.168.100.147
Host is up (0.00064s latency).

PORT   STATE    SERVICE
80/tcp filtered http
MAC Address: 00:0C:29:C0:5F:95 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.40 seconds

┌──(dohongthai-b22dcat278㉿B22DCAT278-DoHongThai-Kali)-[~]
└─$
```

Kết quả log snort nhận được

```
04/09-18:18:06.427099  [**] [1:1000003:1] B22DCAT278-DoHongThai-phat hien dang
bi tan cong tcp syn flood [**] [Priority: 0] {TCP} 192.168.100.148:40302 -> 192
.168.100.147:80
04/09-18:18:06.427099  [**] [1:1000002:1] B22DCAT278-DoHongThai-phat hien co ca
c goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 192.168.100.148:40302 -
> 192.168.100.147:80
04/09-18:18:06.526046  [**] [1:1000003:1] B22DCAT278-DoHongThai-phat hien dang
bi tan cong tcp syn flood [**] [Priority: 0] {TCP} 192.168.100.148:40304 -> 192
.168.100.147:80
04/09-18:18:06.526046  [**] [1:1000002:1] B22DCAT278-DoHongThai-phat hien co ca
c goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 192.168.100.148:40304 -
> 192.168.100.147:80
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort:~$
```

+ Từ máy Kali, sử dụng công cụ hping3 để tấn công TCP SYN Flood máy Snort (dùng lệnh: hping3 -c 15000 -d 120 -S -w 64 -p 80 --flood --rand-source <địa chỉ IP máy Snort>). Trên máy Snort kiểm tra kết quả phát hiện trên giao diện terminal hoặc log của Snort.

```
04/09-18:22:04.421394  [**] [1:1000002:1] B22DCAT278-DoHongThai-phat hien co ca
c goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 213.156.131.95:61730 ->
 192.168.100.147:80
04/09-18:22:04.421441  [**] [1:1000003:1] B22DCAT278-DoHongThai-phat hien dang
bi tan cong tcp syn flood [**] [Priority: 0] {TCP} 23.129.208.162:61731 -> 192.
168.100.147:80
04/09-18:22:04.421441  [**] [1:1000002:1] B22DCAT278-DoHongThai-phat hien co ca
c goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 23.129.208.162:61731 ->
 192.168.100.147:80
04/09-18:22:04.421441  [**] [1:1000003:1] B22DCAT278-DoHongThai-phat hien dang
bi tan cong tcp syn flood [**] [Priority: 0] {TCP} 156.24.96.171:61732 -> 192.1
68.100.147:80
04/09-18:22:04.421441  [**] [1:1000002:1] B22DCAT278-DoHongThai-phat hien co ca
c goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 156.24.96.171:61732 ->
192.168.100.147:80
04/09-18:22:04.432810  [**] [1:1000003:1] B22DCAT278-DoHongThai-phat hien dang
bi tan cong tcp syn flood [**] [Priority: 0] {TCP} 152.78.228.30:61965 -> 192.1
68.100.147:80
04/09-18:22:04.432810  [**] [1:1000002:1] B22DCAT278-DoHongThai-phat hien co ca
c goi tin ra quet tren cong 80 [**] [Priority: 0] {TCP} 152.78.228.30:61965 ->
192.168.100.147:80
dohongthai-b22dcat278@B22DCAT278-DoHongThai-Snort:~$
```

2.3 Kết luận

− Hệ thống phát hiện xâm nhập Snort hoạt động ổn định.

− Các luật mới được tạo và lưu vào trong file luật của Snort.

− Snort phát hiện thành công các rà quét tấn công kể trên.

TÀI LIỆU THAM KHẢO

[1]. Chương 5, Giáo trình Cơ sở an toàn thông tin, Học viện Công nghệ BVCT, 2020.

[2]. Suricata: https://suricata.io/documentation/

[3]. Snort: https://www.snort.org/#documents

[4]. OSSEC: https://www.ossec.net/docs/

[5]. Wazuh: https://documentation.wazuh.com/current/index.html